# SE Lab 5: Static Code Analysis Lab report:-

Name: Shreyas patil

SRN:PES2UG24CS492

Sec:H

The result from the 3 tools before correcting the error

Pylint screenshot:

```
************* Module course_enrollment_system
course_enrollment_system.py:23:0: C0301: Line too long (135/100) (line-too-long)
course_enrollment_system.py:87:0: C0304: Final newline missing (missing-final-newline)
course_enrollment_system.py:1:0: C0114: Missing module docstring (missing-module-docstring)
course_enrollment_system.py:12:0: C0103: Constant name "total_tuition" doesn't conform to UPPER_CASE naming style (invalid-name)
course_enrollment_system.py:15:0: C0116: Missing function or method docstring (missing-function-docstring)
course_enrollment_system.py:15:0: C0103: Function name "enrollStudent" doesn't conform to snake_case naming style (invalid-name)
course_enrollment_system.py:15:0: W0102: Dangerous default value [] as argument (dangerous-default-value)
course_enrollment_system.py:16:4: W0603: Using the global statement (global-statement)
course_enrollment_system.py:23:23: C0209: Formatting a regular string which could be an f-string (consider-using-f-string)
course_enrollment_system.py:27:0: C0116: Missing function or method docstring (missing-function-docstring)
course_enrollment_system.py:27:0: C0103: Function name "dropCourse" doesn't conform to snake_case naming style (invalid-name)
course_enrollment_system.py:31:4: W0702: No exception type(s) specified (bare-except)
course_enrollment_system.py:35:0: C0116: Missing function or method docstring (missing-function-docstring)
course_enrollment_system.py:35:0: C0103: Function name "checkCourseStatus" doesn't conform to snake_case naming style (invalid-name)
course_enrollment_system.py:37:7: C0121: Comparison 'courses.get(course_id) == None' should be 'courses.get(course_id) is None' (singleton-comparison)
course_enrollment_system.py:39:4: R1703: The if statement can be replaced with 'return bool(test)' (simplifiable-if-statement)
course_enrollment_system.py:39:4: R1705: Unnecessary "else" after "return", remove the "else" and de-indent the code inside it (no-else-return)
course_enrollment_system.py:36:4: W0612: Unused variable 'lab_fee' (unused-variable)
course_enrollment_system.py:45:0: C0116: Missing function or method docstring (missing-function-docstring)
course_enrollment_system.py:45:0: C0103: Function name "calculateScholarshipTuition" doesn't conform to snake_case naming style (invalid-name)
course_enrollment_system.py:47:14: W0123: Use of eval (eval-used)
course_enrollment_system.py:46:4: W0612: Unused variable 'base_fee' (unused-variable)
course_enrollment_system.py:51:0: C0116: Missing function or method docstring (missing-function-docstring)
course_enrollment_system.py:51:0: C0103: Function name "generateStudentHash" doesn't conform to snake_case naming style (invalid-name)
course_enrollment_system.py:55:0: C0116: Missing function or method docstring (missing-function-docstring)
course_enrollment_system.py:55:0: C0103: Function name "generateEnrollmentOtp" doesn't conform to snake_case naming style (invalid-name)
course_enrollment_system.py:59:0: C0116: Missing function or method docstring (missing-function-docstring)
course_enrollment_system.py:59:0: C0103: Function name "exportCourseRoster" doesn't conform to snake_case naming style (invalid-name)
course_enrollment_system.py:60:8: W1514: Using open without explicitly specifying an encoding (unspecified-encoding)
course_enrollment_system.py:60:8: R1732: Consider using 'with' for resource-allocating operations (consider-using-with)
course_enrollment_system.py:66:0: C0116: Missing function or method docstring (missing-function-docstring)
course_enrollment_system.py:66:0: C0103: Function name "getOpenCoursesSummary" doesn't conform to snake_case naming style (invalid-name)
course_enrollment_system.py:66:26: W0621: Redefining name 'courses' from outer scope (line 6) (redefined-outer-name)
course_enrollment_system.py:68:8: W0612: Unused variable 'cid' (unused-variable)
course_enrollment_system.py:74:0: C0116: Missing function or method docstring (missing-function-docstring)
course_enrollment_system.py:4:0: W0611: Unused import math (unused-import)

-----------------------------------
Your code has been rated at 4.00/10
```

Bandit Screenshot:

```
bandit : [main] INFO    profile include tests: None
At line:1 char:1
+ bandit course_enrollment_system.py >
bandit_report_before.txt 2>&1
+ ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
~~~~~
    + CategoryInfo          : NotSpecified: ([main]     INFO    profi
   le include tests: None:String) [], RemoteException
    + FullyQualifiedErrorId : NativeCommandError

[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.14.7
Run started:2026-10-14 06:51:07.905301+00:00

Test results:
>> Issue: [B110:try_except_pass] Try, Except, Pass detected.
   Severity: Low   Confidence: High
   CWE: CWE-703 (https://cwe.mitre.org/data/definitions/703.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b110_try_except_pass.html
   Location: .\course_enrollment_system.py:31:4
30              courses[course_id]["is_closed"] = False
31          except:
32              pass
33

--------------------------------------------------
>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer ast.literal_eval.
   Severity: Medium   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval
   Location: .\course_enrollment_system.py:47:14
46          base_fee = courses[course_id]["fee"]
47          net_fee = eval(discount_expr)
48          return net_fee

--------------------------------------------------
```

```
>> Issue: [B324:hashlib] Use of weak MD5 hash for security. Consider usedforsecurity=False
   Severity: High   Confidence: High
   CWE: CWE-327 (https://cwe.mitre.org/data/definitions/327.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b324_hashlib.html
   Location: .\course_enrollment_system.py:52:11
51      def generateStudentHash(roll_no):
52          return hashlib.md5(roll_no.encode()).hexdigest()
53

--------------------------------------------------
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for
security/cryptographic purposes.
   Severity: Low   Confidence: High
   CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-
random
   Location: .\course_enrollment_system.py:56:11
55      def generateEnrollmentOtp():
56          return random.randint(1000, 9999)
57

--------------------------------------------------
>> Issue: [B605:start_process_with_a_shell] Starting a process with a shell, possible
injection detected, security issue.
   Severity: High   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b605
_start_process_with_a_shell.html
   Location: .\course_enrollment_system.py:63:4
62          f.close()
63          os.system("echo Course roster exported to: " + filename)
64

--------------------------------------------------
>> Issue: [B105:hardcoded_password_string] Possible hardcoded password:
'REGISTRAR_PORTAL_ROOT_SECRET_2026'
   Severity: Low   Confidence: Medium
   CWE: CWE-259 (https://cwe.mitre.org/data/definitions/259.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b105
_hardcoded_password_string.html
   Location: .\course_enrollment_system.py:75:27
74      def main():
```

```
74      def main():
75          registrar_auth_token = "REGISTRAR_PORTAL_ROOT_SECRET_2026"
76          enrollStudent("CS101", "Kritika", 4)

--------------------------------------------------

Code scanned:
        Total lines of code: 65
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec
BXXX): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 3
                Medium: 1
                High: 2
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 1
                High: 5
Files skipped (0):
```

# Flake8 Screenshot:

```
course_enrollment_system.py:4:1: F401 'math' imported but unused
course_enrollment_system.py:7:80: E501 line too long (88 > 79 characters)
course_enrollment_system.py:8:80: E501 line too long (89 > 79 characters)
course_enrollment_system.py:9:80: E501 line too long (88 > 79 characters)
course_enrollment_system.py:15:80: E501 line too long (81 > 79 characters)
course_enrollment_system.py:23:80: E501 line too long (135 > 79 characters)
course_enrollment_system.py:31:5: E722 do not use bare 'except'
course_enrollment_system.py:36:5: F841 local variable 'lab_fee' is assigned to but never used
course_enrollment_system.py:37:31: E711 comparison to None should be 'if cond is None:'
course_enrollment_system.py:46:5: F841 local variable 'base_fee' is assigned to but never used
course_enrollment_system.py:79:80: E501 line too long (86 > 79 characters)
course_enrollment_system.py:87:7: W292 no newline at end of file
```

The issues mentioned(included in issues.md)

| Issue | Type | Line(s) | Description | Fix Approach |
|---|---|---|---|---|
| Unsafe `eval()` usage | Security (Medium) | 47 | `eval(discount_expr)` may execute arbitrary code. | Replace with safe, validated discount calculation logic. |
| Weak MD5 hashing | Security (High) | 52 | MD5 is unsuitable for security-sensitive hashing. | Use SHA-256 if a cryptographic hash is required. |
| Shell command execution | Security (High) | 63 | `os.system()` invokes a shell to display the export message. | Replace with Python's `print()` function. |
| Hardcoded authentication token | Security (Low) | 75 | The registrar token is hardcoded in the source file. | Load the token from an environment |

Post code correction , the score that I attained is below:

Pylint:

```
|
--------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 4.00/10, +6.00)
```

## Bandit:

```
python : [main] INFO    profile include tests: None
At line:1 char:1
+ python -m bandit course_enrollment_system.py >
bandit_report_after.tx ...
+ ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
~~~~~~~~~~~~~~~~~~~
    + CategoryInfo          : NotSpecified: ([main]
        INFO    profile include tests: None:String) [], R
  emoteException
    + FullyQualifiedErrorId : NativeCommandError

[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.14.7
Run started:2026-10-14 14:19:11.003215+00:00

Test results:
        No issues identified.

Code scanned:
        Total lines of code: 99
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX):
0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
Files skipped (0):
```

## Flake8 Screenshot:

```
No new line till the end of file
```